

Weekly IT Security Brief (Official-source-first) | 2026-07-12

06:00

Formatted for readability · Auto-generated

Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-56291(2026-07-13), CVE-2026-48939(2026-07-13), CVE-2026-48908(2026-07-10). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Securing our future: July 2026 progress report on Microsoft's Secure Future Initiative. Microsoft's latest Secure Future Initiative report outlines progress on secure foundations, AI-powered defense, and future-ready cybersecurity. The post S...
- Threat trend #2: GigaWiper: Anatomy of a destructive backdoor assembled from multiple malware. GigaWiper is a destructive backdoor that combines multiple wiping and ransomware-like capabilities into a single operational platform. Recommendation: prioritize vu...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.

Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-56291

CVE Title	CVE-2026-56291 balbooa/forms Unknown Type
CVE Description	The Joomla extension Balbooa Forms is vulnerable to an unauthenticated arbitrary file upload that allows uploading executable files and leads to full RCE.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	balbooa/forms
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-13
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-56291

CVE-2026-48939

CVE Title	CVE-2026-48939 joomlic/icagenda Unknown Type
CVE Description	A vulnerability in the iCagenda extension for Joomla allows the upload of arbitrary files in the file attachment feature, ultimately resulting in PHP code upload and execution.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	joomlic/icagenda
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-13
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-48939

CVE-2026-48908

CVE Title	CVE-2026-48908 ollyo/sp_page_builder Unknown Type
CVE Description	A vulnerability in SP Page Builder for Joomla allows unauthenticated users to upload arbitrary files, ultimately resulting in the upload and execution of PHP code.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	ollyo/sp_page_builder
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-10
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-48908

CVE-2026-55255

CVE Title	CVE-2026-55255 langflow/langflow Unknown Type
CVE Description	Langflow is a tool for building and deploying AI-powered agents and workflows. Prior to 1.9.1, an Insecure Direct Object Reference (IDOR) vulnerability in /api/v1/responses endpoint allows an authenticated attacker to execute any flow belonging to another user by specifying the victim's flow ID in the request. This vulnerability is fixed in 1.9.1.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	langflow/langflow
Risk Score	8.4 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-10
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-55255

CVE-2026-56290

CVE Title	CVE-2026-56290 joomla/page_builder_ck Unknown Type
CVE Description	The Joomla extension Page Builder CK is vulnerable to an unauthenticated arbitrary file upload that allows uploading executable files and leads to full RCE.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	joomla/page_builder_ck
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-07-10
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-56290

Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-14655

CVE Title	CVE-2026-14655 待核實 XSS
CVE Description	A weakness has been identified in code-projects Assessment Management 1.0. Affected by this issue is some unknown functionality of the file admin/view-users.php. Executing a manipulation of the argument User can lead to cross site scripting. The attack may be performed from remote. The exploit has been made available to the public and could be used for attacks.
Affected Products	待核實
Risk Score	2.4 (LOW)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-14655

CVE-2026-14656

CVE Title	CVE-2026-14656 待核實 XSS
CVE Description	A security vulnerability has been detected in code-projects Assessment Management 1.0. This affects an unknown part of the file /admin/remove-user.php. The manipulation of the argument ID leads to cross site scripting. It is possible to initiate the attack remotely. The exploit has been disclosed publicly and may be used.
Affected Products	待核實
Risk Score	4.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-14656

CVE-2026-14657

CVE Title CVE-2026-14657 | 待核實 | SQL Injection

CVE Description A flaw has been found in code-projects Assessment Management 1.0. This issue affects some unknown processing of the file /lecturer/marking-scheme.php of the component Database Query Handler. This manipulation of the argument sqquestions[] causes sql injection. The attack can be initiated remotely. The exploit has been published and may be used.

Affected Products 待核實

Risk Score 6.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-14657>

CVE-2026-14658

CVE Title CVE-2026-14658 | 待核實 | SQL Injection

CVE Description A vulnerability was detected in code-projects Assessment Management 1.0. This vulnerability affects unknown code of the file /lecturer/marking-scheme.php. The manipulation of the argument smarksrange[] results in sql injection. It is possible to launch the attack remotely. The exploit is now public and may be used.

Affected Products 待核實

Risk Score 6.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-14658>



Report B: Threat Intelligence News (last 7 days)

Headline: Securing our future: July 2026 progress report on Microsoft's Secure Future Initiative

Source	Microsoft Security Blog
Published	Fri, 10 Jul 2026 16:00:00 +0000
Key Takeaway	Microsoft's latest Secure Future Initiative report outlines progress on secure foundations, AI-powered defense, and future-ready cybersecurity. The post Securing our future: July 2026 progress report on Microsoft's Secure Future Initiative appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/07/10/securing-our-future-july-2026-progress-report-on-microsofts-secure-future-initiative/

Headline: GigaWiper: Anatomy of a destructive backdoor assembled from multiple malware

Source	Microsoft Security Blog
Published	Thu, 09 Jul 2026 15:00:00 +0000
Key Takeaway	GigaWiper is a destructive backdoor that combines multiple wiping and ransomware-like capabilities into a single operational platform. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/07/09/gigawiper-anatomy-of-a-destructive-backdoor-assembled-from-multiple-malware/

Headline: CISA Announces New Advisory Council to Strengthen Partnerships and Secure Critical Infrastructure

Source	CISA News
Published	Wed, 01 Jul 26 12:00:00 +0000
Key Takeaway	CISA Announces New Advisory Council to Strengthen Partnerships and Secure Critical Infrastructure Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	critical infrastructure/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-announces-new-advisory-council-strengthen-partnerships-and-secure-critical-infrastructure

Headline: New CISA Guide Assists Federal Agencies with Transitioning to Modernized Zero Trust Architectures	
Source	CISA News
Published	Wed, 24 Jun 26 12:00:00 +0000
Key Takeaway	New CISA Guide Assists Federal Agencies with Transitioning to Modernized Zero Trust Architectures Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/new-cisa-guide-assists-federal-agencies-transitioning-modernized-zero-trust-architectures

Headline: WolfSSL, GeoVision, VTK vulnerabilities

Source Cisco Talos Blog

Published Thu, 09 Jul 2026 18:52:29 GMT

Key Takeaway Cisco Talos' Vulnerability Discovery & Research team recently disclosed three vulnerabilities in WolfSSF, fourteen in GeoVision, and one vulnerability in VTK-DICOM. The vulnerabilities mentioned in this blog post have been patched by their respective vendors, in adherence to Cisco's third-party vuln Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/wolfssl-vulnerabilities/>

Headline: Winning 54% of the time

Source Cisco Talos Blog

Published Thu, 09 Jul 2026 18:00:06 GMT

Key Takeaway With Wimbledon's help, Hazel argues against the popular myth that "Attackers only need to be right once, but defenders need to be right 100% of the time." Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/winning-54-of-the-time/>

Headline: Compromised jscrambler 8.14.0 npm Release Drops Rust Infostealer During Install

Source	The Hacker News
Published	Sat, 11 Jul 2026 23:29:26 +0530
Key Takeaway	The jscrambler npm package was compromised, and simply installing its 8.14.0 release runs an infostealer on your machine. Published on July 11, 2026, the malicious version carries a preinstall hook that drops and executes a native binary, one build each for Windows, macOS, and Linux. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/07/compromised-jscrambler-8140-npm-release.html

Headline: Hackers Weaponize Balochistan Police Portal in Multi-Group Espionage Campaigns

Source	The Hacker News
Published	Sat, 11 Jul 2026 23:19:31 +0530
Key Takeaway	Cybersecurity researchers have disclosed details of sustained cyber espionage activity against several Pakistani law enforcement organizations undertaken by suspected China- and India-aligned threat actors between February 2024 and April 2026. "At Balochistan Police, the compromised assets included Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/07/hackers-weaponize-balochistan-police.html

Headline: Ghost Accounts Abuse GitHub API in Mass Recon Campaign

Source	SecurityWeek
Published	Sat, 11 Jul 2026 17:30:00 +0000
Key Takeaway	Multiple campaigns are using ghost accounts to map GitHub organizations, including their repositories and members. The post Ghost Accounts Abuse GitHub API in Mass Recon Campaign appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/ghost-accounts-abuse-github-api-in-mass-recon-campaign/

Headline: In Other News: DHS Database Hacked, Adobe Boosts Patch Cadence, Canada Disrupts Ransomware Ops

Source	SecurityWeek
Published	Fri, 10 Jul 2026 15:01:19 +0000
Key Takeaway	Other noteworthy stories that might have slipped under the radar: Abnormal AI sued by Anthropic, AssuranceAmerica data breach affects 7 million people, NSA brings back TAO. The post In Other News: DHS Database Hacked, Adobe Boosts Patch Cadence, Canada Disrupts Ransomware Ops appeared first on Secur Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-dhs-database-hacked-adobe-boosts-patch-cadence-canada-disrupts-ransomware-ops/

Headline: Australia warns of global campaign targeting vulnerable CMS platforms

Source BleepingComputer

Published Sat, 11 Jul 2026 10:18:23 -0400

Key Takeaway The Australian Cyber Security Centre (ACSC) issued an alert about a global exploitation campaign targeting vulnerable content management systems (CMS) and plugins. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target 待核實/global

Technique Exploit Chain

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/australia-warns-of-global-campaign-targeting-vulnerable-cms-platforms/>

Headline: 'Ghostcommit' hides prompt injection in images to fool AI agents, steal secrets

Source	BleepingComputer
Published	Sat, 11 Jul 2026 05:03:57 -0400
Key Takeaway	A PNG hiding a prompt injection could steal your repo's secrets, researchers demonstrate. The technique, dubbed 'Ghostcommit,' slipped past AI code reviewers CodeRabbit and Bugbot, which never open image files at all, then convinced a coding agent to read a repo's .env and write every secret into th Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalou...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/security/ghostcommit-hides-prompt-injection-in-images-to-fool-ai-agents-steal-secrets/



Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

[**https://attack.mitre.org/**](https://attack.mitre.org/)

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)